

Cyberdefenders - Lockdown Lab

PCAP Analysis

After flooding the IIS host with rapid-fire probes, the attacker reveals their origin. Which IP address generated this reconnaissance traffic?

`Capture.pcap` contains recorded network packets and allows for network traffic analysis. It can be opened with Wireshark. By navigating to Statistics → Conversations and looking at the IPv4 tab, we can identify which IP addresses sent the most packets, which allows us to identify the attacker's IP address:

`10.0.2.4`

Zeroing in on a single open service to gain a foothold, the attacker carries out targeted enumeration. Which MITRE ATT&CK technique ID covers this activity?

In Wireshark, we can observe that the attacker sent requests to a large number of ports in order to discover running services. This behavior corresponds to MITRE ATT&CK technique **T1046 - Network Service Discovery**.

(<https://attack.mitre.org/techniques/T1046/>)

While reviewing the SMB traffic, you observe two consecutive Tree Connect requests that expose the first shares the intruder probes on the IIS host. Which two full UNC paths are accessed?

SMB is a Windows protocol used for sharing resources over local networks. The Tree Connect request is used to grant or deny access to a shared resource. In

Wireshark, we can filter SMB2 Tree Connect requests using the filter `smb2.cmd == 3` (3 being the value of the `SMB2_TREE_CONNECT` command) and `smb2.flags.response == 0` (responses have the flag set to 1). This returns all requests to the Tree Connect command.

We can then inspect the SMB2 request body under **Tree Connect Request** → **Tree** to retrieve the requested path, which gives us `\\10.0.2.15\Documents` and `\\10.0.2.15\IPC$`.

`\\10.0.2.15\IPC$` is a hidden system share used internally by Windows. `Documents` is the actual share containing the shared folder.

Inside the share, the attacker plants a web-accessible payload that will grant remote code execution. What is the filename of the malicious file they uploaded, and what byte length is specified in the corresponding SMB2 Write Request?

In Wireshark, we can filter SMB2 Write requests using the filter `smb2.cmd == 9` and `smb2.flags.response == 0`.

By analyzing the SMB2 request body, we can identify the file `shell.aspx` with a length of 1,015,024 bytes.

The newly planted shell calls back to the attacker over an uncommon but firewall-friendly port. Which listening port did the attacker use for the reverse shell?

Since this is a reverse shell, we can start by filtering traffic from the victim to the attacker. We then look for the initial connection by filtering on `tcp.flags.syn == 1` (connection initiation from the victim) and `tcp.flags.ack == 0` (the attacker has not yet acknowledged the request). This reveals a request to port **4443**, which is the attacker's reverse shell port a firewall-friendly port, close to HTTPS (443).

Alternatively, we can navigate to Statistics → Conversations → TCP and look for the port that received the most packets, which also points to port **4443**, confirming that this connection was highly active.

Memory dump analysis

For memory dump analysis, we use **Volatility3**.

Your memory snapshot captures the system's kernel in situ, providing vital context for the breach. What is the kernel base address in the dump?

We can use the `windows.info` plugin from Volatility, which provides details about the operating system and kernel from the memory dump.

```
python vol.py -f ~/Cyber/scenario-1/memdump.mem windows.info
```

This returns a Kernel Base address of `0xf80079213000`.

A trusted service launches an unfamiliar executable residing outside the usual IIS stack, signalling a persistence implant. What is the final full on-disk path of that executable, and which MITRE ATT&CK persistence technique ID corresponds to this behaviour?

With Volatility, we can list all running processes along with their parent processes:

```
python3 vol.py -f ~/Cyber/scenario-1/memdump.mem windows.psree
```

We look for processes related to IIS. IIS worker processes are spawned by `w3wp.exe` ([reference](#)). Since `w3wp.exe` is a level 3 process, we look for a level 4 child

process linked to it. We find `updatenow.exe` located at

`C:\ProgramData\Microsoft\Windows\Start Menu\Programs\Startup\updatenow.exe`.

The path reveals that the malware is located in the Startup folder, meaning it is automatically executed at boot. The corresponding MITRE ATT&CK technique is **T1547 - Boot or Logon Autostart Execution**.

The reverse shell's outbound traffic is handled by a built-in Windows process that also spawns the implanted executable. What is the name of this process, and what PID does it run under?

As noted above, the malware is spawned by the IIS worker process `w3wp.exe`, which has a PID of **4332**.

Malware Sample Analysis

Static inspection reveals the binary has been packed to hinder analysis. Which packer was used to obfuscate it?

To identify the packer, we can use a packer detection tool such as Detect It Easy. Running the following command:

```
diec updatenow.exe
```

reveals that the packer used is **UPX**.

Threat-intel analysis shows the malware beaconing to its command-and-control host. Which fully qualified domain name (FQDN) does it contact?

By computing the hash of the binary and looking it up on VirusTotal, we can see under the **Contacted Domains** tab that `cp8nl.hyperhost.ua` is the only flagged domain contacted by the malware.

***Open-source intel associates that hash with a well-known commodity RAT.
To which malware family does the sample belong?***

Also on VirusTotal, we can see that the malware has been flagged by multiple antivirus engines as a RAT of type **AgentTesla**.